

REGRAS PARA PROTEÇÃO DE DADOS SENSÍVEIS

Projeto Integrador – Sistema Autim

Documento complementar ao modelo conceitual, lógico e físico (MySQL)

São Paulo, 2026

1. INTRODUÇÃO

Este documento estabelece as regras de proteção de dados sensíveis aplicáveis ao Sistema Autim, desenvolvido para apoio a crianças autistas não verbais. As regras estão alinhadas à Lei Geral de Proteção de Dados (LGPD - Lei 13.709/2018) e às boas práticas de segurança da informação, abrangendo dados de alunos (crianças) e usuários (responsáveis e auxiliares).

2. REGRAS DE ACESSO E PERFIL

Estas regras definem quem pode acessar quais dados no sistema, baseado no cargo do usuário.

Regra	Descrição
R01	Apenas usuários com cargo responsável podem vincular ou desvincular um aluno a um auxiliar.
R02	Um auxiliar só pode visualizar dados de alunos aos quais foi explicitamente vinculado via tabela ALUNO_AUXILIAR.

Regra	Descrição
R03	Um responsável pode ver todos os dados do aluno vinculado, incluindo perfil, sessões, rotinas, frases e relatórios.
R04	O sistema deve registrar quem acessou, quando e o que visualizou (log de auditoria - tabela LOG_ACESSO).

3. REGRAS DE PSEUDONIMIZAÇÃO E ANONIMIZAÇÃO

Estas regras visam proteger a identidade do aluno em diferentes contextos de uso do sistema.

Regra	Descrição
R05	O nome do aluno (ALU_NOME) não deve aparecer em relatórios exportados sem autorização explícita do responsável.
R06	Em telas de listagem para auxiliar, exibir apenas identificador codificado (ex: "Aluno A12") e idade aproximada, nunca o nome completo.
R07	Após 180 dias sem nenhuma sessão , o sistema deve solicitar ao responsável se deseja anonimizar os dados do aluno (remover nome e avatar, mantendo apenas

Regra	Descrição
	estatísticas anônimas).

4. REGRAS DE CONSENTIMENTO E VINCULAÇÃO

Estas regras garantem que o responsável tenha controle explícito sobre quem acessa os dados do aluno.

Regra	Descrição
R08	Um aluno só pode ser criado após o aceite do Termo de Consentimento Livre e Esclarecido por um responsável.
R09	O vínculo entre responsável e aluno (ALUNO_USUARIO) exige validação por e-mail ou token enviado ao responsável.
R10	O responsável pode revogar o acesso de um auxiliar a qualquer momento, com efeito imediato.

5. REGRAS DE RETENÇÃO E EXCLUSÃO

Estas regras definem prazos e procedimentos para armazenamento e remoção de dados.

Regra	Descrição
R11	Dados de sessões, rotinas e frases de um aluno podem ser excluídos fisicamente após solicitação do responsável, mantendo apenas agregados estatísticos anônimos.
R12	O responsável pode solicitar a exportação completa de todos os dados do aluno em formato legível (CSV/JSON).
R13	Após solicitação de exclusão de conta do responsável, o sistema aguarda 30 dias antes da exclusão definitiva (período de recuperação).

6. REGRAS TÉCNICAS (BANCO DE DADOS)

Estas regras especificam requisitos de implementação técnica para proteção dos dados.

Regra	Descrição
R14	A coluna USU_SENHA deve ser armazenada apenas com hash (ex: bcrypt), nunca em texto puro.
R15	O e-mail (USU_EMAIL) é considerado dado pessoal sensível no contexto da criança (identificação indireta).

Regra	Descrição
R16	ALU_URLAVATAR não pode conter nome da criança no nome do arquivo ou caminho.
R17	Tabelas com FK para ALUNO devem usar ON DELETE CASCADE apenas quando não houver obrigação legal de retenção.

7. REGRAS DE AUDITORIA E NOTIFICAÇÃO

Estas regras garantem rastreabilidade e transparência sobre o acesso aos dados.

Regra	Descrição
R18	O sistema deve registrar em log (tabela LOG_ACESSO) qualquer acesso a PERFIL, RELATORIO ou FRASE de um aluno.
R19	O responsável deve ser notificado por e-mail sempre que um novo auxiliar for vinculado ao seu filho.
R20	Em caso de violação de acesso (tentativa de acesso não autorizado), o sistema deve bloquear o usuário e notificar o responsável.

8. RESUMO PARA DOCUMENTAÇÃO DO PROJETO

O sistema adota as regras R01 a R20 descritas neste documento, garantindo:

- *Apenas responsáveis e auxiliares autorizados acessam dados de alunos.*
- *Todo acesso a dados sensíveis é registrado em logs de auditoria.*
- *O consentimento explícito é obrigatório para criação de aluno.*
- *Dados são anonimizados ou excluídos conforme solicitação do responsável.*
- *Senhas e identificadores indiretos são protegidos criptograficamente.*
- *Notificações automáticas garantem transparência sobre acessos e vínculos.*

9. REFERÊNCIAS

- ---

Lei Geral de Proteção de Dados Pessoais (LGPD) - Lei nº 13.709/2018.
- ISO/IEC 27001: Segurança da Informação.
- Boas práticas para sistemas educacionais com dados de menores - ANEP/2022.